

Informe de Pentesting

Actividad A08 — Hacking Ético

Cliente: INSECUR S.A.

Laboratorio: TryHackMe

Seguridad Aplicada a Sistemas de Información

Alumno/a	Enzo Manrique
Username TryHackMe	manriqueenzo
Docente	Ing. Rodrigo Atilio Elgueta
Fecha de entrega	08/10/2026

1. Datos generales

Campo	Valor
Cliente	INSECUR S.A.
Contratista (alumno/a)	Enzo Manrique
DNI	44438747
Username TryHackMe	manriqueenzo
Email institucional	manriqueenzo@uch.edu.ar
Sala de elección	Vulniversity
Branch en GitHub	manrique-enzo
Fecha de inicio	07/10/2026
Fecha de cierre	09/10/2026

2. Pre-pentesting

Alcance del trabajo

El alcance de este trabajo comprende exclusivamente los entornos de laboratorio provistos por la plataforma TryHackMe, específicamente las salas "Pentesting Fundamentals", "Basic Pentesting" (núcleo obligatorio) y "Vulniversity" (sala de elección, Nivel 2). Quedan excluidos de forma explícita todos los sistemas de producción de INSECUR S.A., así como cualquier otro sistema, red o servicio no provisto específicamente por la cátedra para esta actividad.

Reglas de Enfrentamiento (ROE)

Las pruebas se realizaron únicamente contra las direcciones IP asignadas dinámicamente por TryHackMe a través de la VPN provista por la plataforma, en el marco temporal de las sesiones de laboratorio activas. No se utilizaron técnicas destructivas (no se buscó denegación de servicio deliberada), no se realizaron ataques de fuerza bruta masivos sin acotar su alcance, y toda herramienta se usó respetando los límites del laboratorio. Ante cualquier comportamiento anómalo del servicio, el procedimiento fue reiniciar la máquina desde la propia plataforma antes de continuar.

Autorización

Declaro que las actividades descriptas en este informe fueron realizadas en el marco de la actividad académica A08 de la cátedra Seguridad Aplicada a Sistemas de Información, contando con autorización expresa de la cátedra para operar sobre los entornos de laboratorio de TryHackMe indicados en la guía de la actividad. No se realizó ninguna acción sobre sistemas reales o de producción.

Metodología utilizada

Se utilizó como referencia metodológica el marco PTES (Penetration Testing Execution Standard), adaptado a las fases sugeridas por la guía de la cátedra: reconocimiento, escaneo, enumeración, explotación y post-explotación. Se eligió PTES por ser un estándar ampliamente reconocido en la industria, de estructura clara y aplicable a entornos de laboratorio controlados como el de esta actividad.

3. Durante: Hallazgos por fase

Para cada hallazgo relevante, completá una tabla. Copiá y pegá una tabla completa si necesitás más hallazgos y cambiá el ID (H-04, H-05...).

Hallazgo H-01

Campo	Valor
ID del hallazgo	H-01
Sala / máquina	Vulniversity
Fase	☐ Reconocimiento X Escaneo ☐ Explotación ☐ Post-explotación
Descripción	Escaneo de puertos con nmap reveló 6 servicios expuestos: FTP (vsftpd 3.0.5), SSH (OpenSSH 8.2p1), Samba (SMB, puertos 139/445), proxy Squid 4.10 y un servidor web Apache 2.4.41 en el puerto 3333.
Componente afectado	Superficie de red general de la máquina.
Categoría (OWASP / CWE)	CWE-200 — Exposure of Information
CVE (si aplica)	(Ej.: CVE-XXXX-XXXXX o "No aplica")
CVSS estimado	X Bajo ☐ Medio ☐ Alto ☐ Crítico
Evidencia (captura / comando)	Guardada como "escaneo_H-01.png" dentro de evidencias/escaneo/
Herramienta utilizada	Nmap
Impacto en la Tríada CIA	X Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Restringir servicios innecesarios expuestos a internet (ej. proxy Squid, SMB) y aplicar firewall con reglas de mínimo privilegio.
Riesgo residual tras aplicar	X Bajo ☐ Medio ☐ Alto

Hallazgo H-02

Campo	Valor
ID del hallazgo	H-02
Sala / máquina	Vulniversity
Fase	☐ Reconocimiento ☐ Escaneo ☒ Explotación ☐ Post-explotación
Descripción	Mediante Gobuster se identificó la ruta no enlazada públicamente /internal/, que expone un formulario de carga de archivos sin autenticación. Se detectó que el servidor filtra las extensiones .php, .php3, .php4, .php5 y .pht (responde "Extension not allowed"), pero no bloquea la extensión .phtml. Se subió un archivo test.phtml con código PHP (<?php echo 'test'; ?>), confirmando que el servidor lo ejecuta como código en /internal/uploads/test.phtml. Esto permite ejecución remota de código (RCE) en el servidor.
Componente afectado	/internal/index.php (formulario) y /internal/uploads/ (carpeta donde se ejecutan los archivos subidos)
Categoría (OWASP / CWE)	CWE-434 — Unrestricted Upload of File with Dangerous Type
CVE (si aplica)	No aplica (falla de configuración propia de la app, no una CVE pública conocida)
CVSS estimado	☐ Bajo ☐ Medio ☐ Alto ☒ Crítico
Evidencia (captura / comando)	enumeracion_H-02_gobuster.png (resultado de gobuster), explotacion_H-02_upload.png (curl mostrando "Success"), explotacion_H-02_rce.png (curl ejecutando el .phtml y devolviendo "test")
Herramienta utilizada	Gobuster, curl.
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☒ Disponibilidad
Salvaguarda propuesta	Validar el tipo de archivo por whitelist estricta (solo extensiones explícitamente permitidas, nunca por lista negra), verificar el contenido real del archivo (magic bytes/MIME type) en vez de confiar en la extensión, y almacenar los archivos subidos fuera del directorio ejecutable por el servidor web (o con permisos que impidan ejecución).
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

Hallazgo H-03

Campo	Valor
ID del hallazgo	H-03
Sala / máquina	Vulniversity
Fase	☐ Reconocimiento ☐ Escaneo ☐ Explotación ☒ Post-explotación
Descripción	Descripción: Mediante LinPEAS se identificaron binarios con permiso SUID, destacándose /bin/systemctl, el cual permite a un usuario sin privilegios crear y habilitar un servicio de systemd arbitrario. Se explotó esta configuración incorrecta creando un servicio personalizado cuyo ExecStart ejecutaba comandos con privilegios de root, logrando leer /etc/shadow y extraer la flag de root ubicada en /root/root.txt, confirmando la escalada completa de privilegios de www-data a root.
Componente afectado	/bin/systemctl (permiso SUID mal configurado)
Categoría (OWASP / CWE)	CWE-269 — Improper Privilege Management
CVE (si aplica)	No aplica (falla de configuración del sistema, no una CVE pública)
CVSS estimado	☐ Bajo ☐ Medio ☐ Alto ☒ Crítico
Evidencia (captura / comando)	postexplotacion_H-03_suid.png, postexplotacion_H-03_root_shadow.png, postexplotacion_H-03_rootflag.png
Herramienta utilizada	LinPEAS, systemctl
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☒ Disponibilidad
Salvaguarda propuesta	Eliminar el permiso SUID de /bin/systemctl (no es un uso estándar ni necesario para su funcionamiento normal), y realizar una auditoría periódica de binarios con SUID/SGID en el sistema, ya que su presencia no justificada es una de las vías más comunes de escalada de privilegios en Linux.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

4. Resumen ejecutivo de hallazgos

Severidad	Cantidad	ID de hallazgos
Crítico	2	H-02, H-03
Alto	0	-
Medio	0	-
Bajo	1	H-01
Total	3	

5. Post-pentesting: Recomendaciones

Recomendaciones técnicas (parches y configuraciones)

1. (Prioridad alta) Implementar validación estricta de tipo de archivo en el formulario de carga ubicado en /internal/, mediante whitelist de extensiones permitidas y verificación del contenido real del archivo (magic bytes), no solo su extensión.
2. (Prioridad alta) Reubicar la carpeta de archivos subidos (/internal/uploads/) fuera del directorio servido por Apache, o configurar el servidor para que no ejecute scripts PHP dentro de esa ruta.
3. (Prioridad media) Restringir el acceso a rutas administrativas no enlazadas públicamente (como /internal/) mediante autenticación, en vez de depender de que no sean descubiertas.
4. (Prioridad baja) Reducir la superficie de ataque cerrando o restringiendo servicios no esenciales detectados en el escaneo inicial (proxy Squid, SMB) si no son necesarios para la operación del servidor.

Recomendaciones administrativas (políticas y procesos)

1. Incorporar revisiones periódicas de seguridad (pentesting interno o externo) antes de exponer nuevos formularios o funcionalidades de carga de archivos.
2. Capacitar al equipo de desarrollo en prácticas seguras de manejo de archivos subidos por usuarios (OWASP File Upload Cheat Sheet).
3. Establecer un proceso formal de gestión de vulnerabilidades, con plazos definidos de remediación según criticidad.

6. Protocolo de contingencia

Escenario de falla

El procedimiento de mayor riesgo realizado durante esta intervención fue la carga de un archivo `.phtml` con código ejecutable al servidor, explotando una falla de validación de extensiones. Si se repitiera este procedimiento sobre un entorno de producción sin las debidas precauciones, podría resultar en ejecución de código no controlado, afectando la disponibilidad del servicio web o comprometiendo la integridad de los datos almacenados en el servidor.

Impacto sobre la continuidad del negocio

De ocurrir en producción, se vería afectado el servicio web público de INSECUR S.A., incluyendo cualquier funcionalidad que dependa del servidor Apache comprometido. El tiempo de afectación dependería de la rapidez de detección y de si existen backups y planes de recuperación ya probados; en un escenario no controlado podría implicar horas de indisponibilidad del sitio.

Plan de respuesta

Activación: La falla se detectaría mediante el monitoreo de logs del servidor web (Apache) y alertas de un sistema de detección de intrusos (IDS/WAF), que registrarían la subida de un archivo con extensión inusual (.phtml) y su posterior ejecución. También sería detectable por un aumento anómalo en el uso de CPU/red o por la aparición de archivos no reconocidos en el directorio de subidas.

Contención: Deshabilitar temporalmente el formulario de carga de archivos (desactivar la ruta `/internal/` o detener el servicio Apache si la gravedad lo amerita). Aislar el servidor de la red si se sospecha que el atacante ya obtuvo una shell activa, cortando la conexión saliente para impedir una reverse shell en curso.

Recuperación: Eliminar los archivos maliciosos subidos, restaurar el servidor desde el último backup o snapshot limpio previo al incidente, y aplicar el parche de validación de archivos (whitelist de extensiones) antes de volver a habilitar el servicio en producción.

Comunicación: Notificar de inmediato al equipo de IT/seguridad interno y a la dirección de INSECUR S.A. Si se confirma que hubo acceso a datos de clientes, corresponde evaluar la notificación a los afectados y, según la normativa vigente, a la autoridad de protección de datos correspondiente.

Post-mortem: Se elabora un informe post-incidente detallando la línea de tiempo, el vector de entrada explotado, el impacto real, y las acciones correctivas aplicadas. Se actualizan las políticas de desarrollo seguro y se agenda una revisión de seguridad de seguimiento para confirmar que la vulnerabilidad fue efectivamente corregida.

RTO y RPO estimados

RTO (Recovery Time Objective): 4hrs

RPO (Recovery Point Objective): 24 horas

7. Anexos

Anexo A — Bitácora de comandos

- bitacora/nmap_inicial.txt — primer escaneo de puertos (IP 10.66.150.144)
- bitacora/nmap_nuevo.txt — escaneo tras reinicio de la máquina (IP 10.67.191.104)
- bitacora/gobuster.txt — enumeración de directorios web
- bitacora/linpeas_output.txt — resultado de LinPEAS (enumeración de post-explotación)
- bitacora/50689.txt — exploit de referencia (PwnKit) utilizado en el intento de escalada
- bitacora/pwnkit/ — código fuente y binarios del exploit utilizado (evil-so.c, exploit.c)
- Comandos de escalada de privilegios (systemctl link/enable) documentados en el hallazgo H-03 y en las capturas del Anexo B.

Anexo B — Capturas de pantalla

- explotacion_H-02_gobuster.png — descubrimiento de la ruta /internal/
- explotacion_H-02_upload.png — subida exitosa del archivo .phtml
- explotacion_H-02_rce.png — confirmación de ejecución remota de código
- postexplotacion_H-03_suid.png — permiso SUID activo en /bin/systemctl
- postexplotacion_H-03_root_shadow.png — lectura de /etc/shadow como root
- postexplotacion_H-03_rootflag.png — obtención de la root flag

Anexo C — Hashes de las flags obtenidas

Formato: flag_id — sha256_hash

H-01 (user flag) — d324bd433001e5bdfe39e04d794539c15b51982a5bf6fc78efea46369b7bf956

H-03 (root flag) — cfbc740435ad60030304080e35131ffcaf8ac5f71b65e002f5b546aa3cda7ce8

Anexo D — Declaración ética firmada

Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados y con fines exclusivamente académicos.

Enzo Manrique

09/10/2026

Firma del estudiante

Fecha